

# REPORTE DE HARDENING

## Windows Server — SQL Server Express

|                     |                                                         |
|---------------------|---------------------------------------------------------|
| Documento           | Reporte de Pruebas de Acceso y Hardening Windows Server |
| Version             | 1.0                                                     |
| Clasificacion       | Confidencial                                            |
| Norma de referencia | ISO/IEC 27001:2022 — Anexo A                            |
| Servidor            | WIN-Q72GACEPUDL — 192.168.1.100                         |
| Sistema Operativo   | Windows Server 2025 Standard                            |
| Base de datos       | SQL Server Express 2022 — MSC_PROD                      |
| Autor               | Andres Martin Sinecio                                   |
| Fecha               | Mayo 2026                                               |

---

# 1. Introduccion

---

El presente documento describe las actividades de hardening realizadas sobre un servidor Windows Server 2025 con SQL Server Express que soporta la base de datos de produccion MSC\_PROD. Las medidas implementadas se alinean con los controles del Anexo A de la norma ISO/IEC 27001:2022, enfocandose en control de acceso, gestion de usuarios, seguridad de base de datos y continuidad del negocio mediante respaldos automaticos.

## 1.1 Objetivo

Asegurar el acceso a los servicios de base de datos SQL Server mediante control de acceso granular por usuario, restricciones de conexion local/remota, firewall perimetral y proceso automatico de respaldo bajo la regla 3-2-1 con almacenamiento en nube.

## 1.2 Alcance

El alcance de este documento abarca:

- Control de acceso local y remoto para 3 usuarios de SQL Server mediante Logon Triggers
- Configuracion de Firewall Windows para acceso al puerto 1433 por red LAN y VPN
- Proceso de respaldo 3-2-1: R1 automatico (6:01 PM), R2 automatico (5:01 AM), R3 manual remoto
- Respaldo en nube mediante OneDrive cada hora dentro del horario 7 AM a 5 PM

## 2. Informacion del Sistema

---

| Parametro                     | Valor                                                                 |
|-------------------------------|-----------------------------------------------------------------------|
| Sistema Operativo             | Windows Server 2025 Standard                                          |
| Nombre del servidor           | WIN-Q72GACEPUDL                                                       |
| IP Local                      | 192.168.1.100                                                         |
| IP VPN Pool                   | 192.168.1.220 — 192.168.1.230                                         |
| Motor de base de datos        | SQL Server Express 17.0 (RTM)                                         |
| Base de datos principal       | MSC_PROD (80 MB)                                                      |
| Instancia SQL                 | .\SQLEXPRESS                                                          |
| Ruta de respaldos SQL         | C:\Program Files\Microsoft SQL Server\MSSQL17.SQLEXPRESS\MSSQL\Backup |
| Unidad de respaldo secundario | D:\ (2 TB disponibles)                                                |
| Almacenamiento en nube        | OneDrive —<br>C:\Users\Administrator\OneDrive\Respaldos_MSC_PROD      |

## 3. Controles de Seguridad Implementados

### 3.1 Gestion de Usuarios y Control de Acceso SQL Server

Referencia ISO/IEC 27001:2022: A.8.2 — Derechos de acceso privilegiado, A.8.3 — Restriccion de acceso.

Se configuraron 3 usuarios de SQL Server con distintos niveles de acceso local y remoto mediante Logon Triggers a nivel de servidor:

| Usuario   | Rol SQL  | Acceso Local | Acceso Remoto | Descripcion                                                                   |
|-----------|----------|--------------|---------------|-------------------------------------------------------------------------------|
| usr_admin | db_owner | SI           | SI            | Administrador completo. Acceso local y remoto sin restricciones.              |
| usr_pt    | ROL_PT   | SI           | NO            | Usuario de planta. Solo puede conectarse desde la maquina local del servidor. |
| usr_pd    | ROL_PD   | NO           | SI            | Usuario remoto. Solo puede conectarse desde conexiones de red/VPN.            |

#### Implementacion mediante Logon Triggers:

Se crearon dos triggers a nivel de servidor que se ejecutan en cada intento de conexion y validan la IP de origen:

```
tr_restrict_usr_pt - Bloquea conexiones remotas para usr_pt (permite solo <local machine>, 127.0.0.1, ::1)
tr_restrict_usr_pd - Bloquea conexiones locales para usr_pd (bloquea <local machine>, 127.0.0.1, ::1)
```

### 3.2 Configuracion de Firewall Windows

Referencia ISO/IEC 27001:2022: A.8.20 — Seguridad de redes, A.8.21 — Seguridad de servicios de red.

| Regla                           | Puerto     | Protocolo  | Red permitida                   | Accion |
|---------------------------------|------------|------------|---------------------------------|--------|
| SQL Server TCP<br>1433 LAN VPN  | 1433       | TCP        | 192.168.1.0/255.255.255.0       | ALLOW  |
| SQL Server TCP<br>1433 VPN Pool | 1433       | TCP        | 192.168.1.220-<br>192.168.1.230 | ALLOW  |
| Resto del trafico               | Cualquiera | Cualquiera | Fuera de rangos anteriores      | DENY   |

### 3.3 Proceso de Respaldo 3-2-1

Referencia ISO/IEC 27001:2022: A.8.13 — Copias de respaldo, A.5.29 — Seguridad durante interrupcion.

La regla 3-2-1 establece: 3 copias, en 2 medios distintos, con 1 copia fuera del sitio. Se implementaron 4 mecanismos de respaldo:

| Respaldo | Tipo             | Horario           | Destino                                | Formato |
|----------|------------------|-------------------|----------------------------------------|---------|
| R1       | SQL automatico   | 6:01 PM diario    | C:\...\MSSQL\Backup\ (mismo servidor)  | BAK     |
| R2       | Copia automatica | 5:01 AM diario    | D:\Respaldos\R2\ (unidad secundaria)   | BAK     |
| R3       | Manual remoto    | A demanda         | Maquina local del administrador remoto | BAK     |
| Nube     | Copia automatica | Cada hora 7AM-5PM | OneDrive\Respaldos_MSC_PROD\           | BAK     |

### Scripts y tareas programadas:

```
C:\Scripts\backup_R1.ps1 - Tarea: Respaldo_R1_SQL_6PM (18:01 diario)
C:\Scripts\backup_R2.ps1 - Tarea: Respaldo_R2_5AM (05:01 diario)
C:\Users\amsin\Desktop\backup_R3.ps1 - Ejecucion manual remota
C:\Scripts\backup_onedrive.ps1 - Tarea: Respaldo_OneDrive_Horario (cada hora 7AM-5PM)
```

## 4. Pruebas de Acceso y Funcionamiento

---

| ID    | Prueba                                    | Resultado esperado                 | Resultado obtenido               | Estado |
|-------|-------------------------------------------|------------------------------------|----------------------------------|--------|
| PR-01 | usr_pt conecta localmente al servidor SQL | Acceso concedido                   | Conexion exitosa                 | PASS   |
| PR-02 | usr_pt intenta conectar remotamente       | Acceso denegado por trigger        | Login failed / trigger activo    | PASS   |
| PR-03 | usr_pd conecta remotamente via VPN        | Acceso concedido                   | Conexion exitosa                 | PASS   |
| PR-04 | usr_pd intenta conectar localmente        | Acceso denegado por trigger        | Login failed / trigger activo    | PASS   |
| PR-05 | usr_admin conecta localmente              | Acceso concedido                   | Conexion exitosa                 | PASS   |
| PR-06 | usr_admin conecta remotamente via VPN     | Acceso concedido                   | Conexion exitosa                 | PASS   |
| PR-07 | Ejecucion manual script R1                | Archivo .bak generado en Backup/   | MSC_PROD_fecha.bak (17 MB)       | PASS   |
| PR-08 | Ejecucion manual script R2                | Copia en D:\Respaldos\R2\          | MSC_PROD_fecha.bak copiado       | PASS   |
| PR-09 | Ejecucion manual script R3 remoto         | Archivo .bak en maquina local      | MSC_PROD_R3_fecha.bak en Desktop | PASS   |
| PR-10 | Ejecucion manual script OneDrive          | Archivo copiado a OneDrive         | Archivo sincronizado a nube      | PASS   |
| PR-11 | Verificacion tareas programadas           | 4 tareas activas en Task Scheduler | Todas en estado Ready            | PASS   |

| ID    | Prueba                                         | Resultado esperado              | Resultado obtenido | Estado |
|-------|------------------------------------------------|---------------------------------|--------------------|--------|
| PR-12 | Conexion al puerto 1433 desde IP no autorizada | Conexion bloqueada por firewall | Connection timeout | PASS   |

## 5. Matriz de Cumplimiento ISO/IEC 27001:2022

---

| Control | Descripcion                            | Implementacion                                                                    | Estado   |
|---------|----------------------------------------|-----------------------------------------------------------------------------------|----------|
| A.8.2   | Derechos de acceso privilegiado        | usr_admin como db_owner con acceso completo, roles limitados para usr_pt y usr_pd | CUMPLIDO |
| A.8.3   | Restriccion de acceso a la informacion | Logon Triggers restringen acceso local/remoto por usuario                         | CUMPLIDO |
| A.8.5   | Autenticacion segura                   | Autenticacion mixta SQL Server + Windows, logins individuales por usuario         | CUMPLIDO |
| A.8.20  | Seguridad de redes                     | Firewall Windows con reglas especificas para puerto 1433 por rango de IP          | CUMPLIDO |
| A.8.21  | Seguridad de servicios de red          | Acceso SQL Server restringido a red LAN y pool VPN unicamente                     | CUMPLIDO |
| A.8.13  | Copias de respaldo de la informacion   | Regla 3-2-1: R1 (6PM), R2 (5AM), R3 (manual remoto), OneDrive (horario)           | CUMPLIDO |
| A.5.29  | Seguridad durante interrupcion         | Respaldo offsite en OneDrive, respaldo en unidad secundaria D:\                   | CUMPLIDO |
| A.8.6   | Gestion de capacidad                   | Limpieza automatica de respaldos en D:\ para gestionar espacio                    | CUMPLIDO |

## 6. Conclusiones

---

Se implementaron exitosamente los controles de seguridad del Anexo A de la norma ISO/IEC 27001:2022 sobre el servidor Windows Server 2025 con SQL Server Express que aloja la base de datos de produccion MSC\_PROD. Los resultados obtenidos demuestran que:

- El control de acceso granular mediante Logon Triggers garantiza que cada usuario solo puede conectarse desde el origen permitido (local o remoto).
- El firewall Windows restringe el acceso al puerto 1433 unicamente a rangos de IP autorizados (LAN y VPN).
- El proceso de respaldo 3-2-1 cubre las tres copias requeridas en dos medios distintos con una copia fuera del sitio en OneDrive.
- Las tareas programadas garantizan la automatizacion de los respaldos sin intervencion manual en los horarios establecidos.
- El respaldo R3 manual remoto permite al administrador obtener una copia local desde cualquier punto de acceso remoto.

Todos los controles implementados superaron satisfactoriamente las 12 pruebas definidas (12/12 PASS), validando la efectividad del proceso de hardening realizado sobre el servidor Windows.

---